

Amperê

Governança, segurança da informação e aquisição de usuários sobre um MVP que já está no ar.

EQUIPE

Guilherme Costa Proença · RM 98937
Eduarda Q. Shiratsu · RM 551188
Hugo Antônio de Oliveira · RM 550153

APLICAÇÃO

ampere-dashboard-six.vercel.app
github.com/GuilhermeCostaProenca/ampere-dashboard

VÍDEO-PITCH

<https://youtu.be/L-FT-pk3LX8>

O que mudou desde a fase anterior

PUBLICADO

Saiu do localhost

Front e API na mesma origem, como função serverless. Banco PostgreSQL gerenciado, com 8 migrations aplicadas.

CORRIGIDO

Três defeitos reais

Roteamento de produção que matava rotas aninhadas; CORS que recusava o próprio front; e um README descrevendo arquitetura que nunca existiu.

NOVO

Landing pública

Página de entrada com o problema, o NILM, o produto e os planos — base da estratégia de aquisição da Parte 5.

O simulador publica no mesmo endpoint do firmware: quando o hardware entrar, nada muda do backend para frente.

Plano de adequação

PERGUNTA	RESPOSTA
Que dados?	Nome, e-mail, tipo de imóvel, plano · dados do dispositivo · curva de consumo a cada 15 min
Base legal	Execução de contrato (conta e telemetria) · Legítimo interesse (segurança) · Consentimento (marketing)
Encarregado	Guilherme Costa Proença · canal privacidade@ampere.app · decisão de incidente é colegiada
Controles	RLS em 8 tabelas · token por requisição · chave própria do dispositivo · validação de esquema · minimização
Incidente	ANPD e titulares em 3 dias úteis (Resolução CD/ANPD nº 15/2024) · direitos do titular em 15 dias

Consumo elétrico não é dado sensível na lei — mas revela rotina de sono, banho e presença em casa. Tratamos como se fosse.

ISO/IEC 38500 em uma startup de três pessoas

PRINCÍPIO	ENCAMINHAMENTO
Responsabilidade	Matriz escrita de quem decide o quê; risco é decisão colegiada
Estratégia	NILM isolado atrás de interface porque o roadmap prevê trocar a heurística por modelo treinado
Aquisição	Critério escrito de fornecedor: custo, portabilidade, LGPD e dependência
Desempenho	Medimos a qualidade do NILM; falta medir disponibilidade e latência
Conformidade	LGPD agora; norma elétrica antes de vender o kit
Comportamento humano	A informação precisa levar a uma ação útil, não a culpa

Avaliar custo, risco e acurácia, mensal · **Dirigir** controles priorizados na sprint · **Monitorar** saúde, advisors e prazos de titular

Riscos reais, lidos no nosso próprio código

#	RISCO	OWASP	SEV.
R1	Backend usa chave de serviço que contorna o RLS — o escopo depende de cada query lembrar do filtro	A01	Alta
R2	Sem limitação de taxa em login, cadastro e ingestão	A07 · A04	Alta
R3	Chave do dispositivo em texto puro, sem rotação nem revogação	A02	Alta
R6	Sem trilha de auditoria: incidente não pode ser reconstruído	A09	Alta
R10	Banco em plano gratuito é pausado por inatividade e derruba tudo	A04	Alta
—	Injeção e SSRF avaliados: consulta parametrizada e validação de esquema, sem vetor	A03 · A10	Baixa

Dez riscos mapeados, cada um apontando o arquivo onde a condição existe.

O que fazer e como conferir depois

CONTROLES IMEDIATOS

- Acesso ao banco só por função que exige o id do usuário
- Teste automatizado que tenta ler dado alheio e deve falhar
- Limitação de taxa por IP e por chave
- Registro estruturado de autenticação, ingestão e exclusão

AUDITORIA

- Acessos de usuário e privilegiados
- RLS e consultas sem filtro
- Toda mudança de schema com migration versionada
- Pedidos de titular atendidos no prazo

ISO 27000

- 27001 e 27002 — política, acesso, log, vulnerabilidade
- 27005 — gestão de risco
- 27017 e 27018 — nuvem e dados pessoais em nuvem
- 27701 — privacidade

Contínuo: dependências e saúde · Mensal: advisors e trilha · Semestral: acessos e restauração de backup

Quem tem o problema não busca por “NILM”

ETAPA	AÇÃO	INDICADOR
Atrair	Páginas por aparelho: “quanto gasta um chuveiro elétrico”, “quanto consome ar-condicionado por hora”	Sessões orgânicas e posição média
Converter	Calculadora gratuita de custo por aparelho; e-mail só com consentimento específico	3% a 5% de visitante para cadastro
Relacionar	Sequência de 4 e-mails, do maior vilão da conta ao convite para o plano gratuito	Abertura e clique
Ativar	Dispositivo conectado e telemetria chegando	60% dos cadastros
Crescer	Síndicos e administradoras: o canal B2B, de maior valor por contato	Custo de aquisição abaixo da margem

A isca entrega de graça uma versão pequena do produto: a resposta para “quanto isso me custa”.

FECHAMENTO

De “o sistema funciona” para “o sistema é confiável”

ENTREGUE

MVP publicado, plano de LGPD, governança pela ISO/IEC 38500 e dez riscos mapeados no próprio código.

PRÓXIMO

Limitação de taxa, trilha de auditoria e hash da chave de ingestão — já priorizados na sprint.

DEPOIS

Hardware físico, modelo treinado de NILM e piloto em condomínio.

ampere-dashboard-six.vercel.app · github.com/GuilhermeCostaProenca/ampere-dashboard · vídeo: <https://youtu.be/L-FT-pk3LX8>